Informe de inteligencia de amenazas (borrador para el capítulo de Resultados)

Borrador v1 · 4 de noviembre de 2026. Cifras del analizador (`informe_resumen.txt` y `mitre_mapping.csv`, con la regla `echo xsec`) salvo las marcadas con (*), calculadas directamente sobre el `cowrie.json` completo. Los huecos [FIGURA n] se rellenan con las gráficas de `analisis\final\`.

1. Resumen ejecutivo

- Durante **28 días** (4 de octubre a 1 de noviembre de 2026) el honeypot registró **216.222 sesiones** desde **4.028 direcciones IP** distintas y 119 países, sin publicitarse en ningún sitio. Equivale a una media de **7.456 conexiones diarias** desde el primer día: un servidor SSH nuevo en Internet es descubierto y atacado en cuestión de minutos.
- La actividad es casi totalmente automatizada. Solo el **34,7 %** de las sesiones (*) ejecuta algún comando; el resto son fuerza bruta o sondeos. Se probaron **199.530 intentos de login** y se capturaron **102.743 comandos** y **7.231 ficheros** (56 distintos).
- Las IP atacantes son **efímeras**: el **79,5 %** (*) aparece un solo día y cada semana surgen entre 900 y 1.050 IP nuevas. Un bloqueo por lista de IP tiene poco valor frente a la huella HASSH del cliente y el comportamiento.
- Se identificaron **seis familias de actividad** por huella HASSH, entre ellas la botnet **Outlaw** (inyección de clave SSH con la firma `mdrfckr`, desde 1.190 IP), un volcado de binarios **RedTail** (criptominado) y una campaña de subida de un fichero `.16` por SFTP desde el 24 de octubre.
- La actividad se mapea a **24 técnicas MITRE ATT&CK en 9 tácticas**. Las más frecuentes: acceso con cuentas válidas (T1078.003), fuerza bruta (T1110.001), descubrimiento del sistema (T1082) y manipulación de claves SSH (T1098.004).
- **Recomendaciones principales:** desactivar la autenticación por contraseña en SSH (solo claves), prohibir el acceso remoto como `root`, deshabilitar el reenvío de puertos TCP y filtrar el tráfico saliente.

2. Metodología y límites

- Sensor único: un honeypot de media interacción (Cowrie 3.1.0) con persona Debian 12, expuesto en el puerto 22 de un servidor cloud en Núremberg. Los datos reflejan lo que ataca a **este** sensor, no una muestra representativa de Internet.
- El honeypot acepta credenciales por política (`root`, `admin` y `ubuntu` con la mayoría de contraseñas). Por eso el **47,0 % de logins "exitosos"** (93.830) mide la política del señuelo y no la eficacia de ningún atacante.
- Se excluyeron **213 eventos de pruebas propias** (3 IP, incluidas las del ataque controlado desde Kali).
- El país es el del **proveedor de la IP** (ip-api.com), no el del atacante: las IP de alquiler en la nube dan una geografía engañosa.
- Los comandos y ficheros capturados son los que el señuelo deja ejecutar; no hay ejecución real de binarios.

3. Evolución temporal

Semana	Sesiones	IP distintas	IP nuevas
1 (4–10 oct.)	56.951	1.033	1.033
2 (11–17 oct.)	54.464	1.120	950
3 (18–24 oct.)	59.471	1.145	902
4 (25–31 oct.)	38.971	1.433	1.053
5 (solo 1 nov.)	6.436	166	92

(*) La semana 5 es parcial.

[FIGURA 1: `timeline.png`]

El día de mayor actividad fue el **10 de octubre** (30.086 sesiones), por la campaña de verificación de credenciales de la huella `30d8…`. El 20 y 21 de octubre se registraron 12.937 y 23.428 sesiones; el 91–93 % de ellas con cliente `SSH-2.0-Go`. La causa principal del segundo pico es **una sola IP** de un proveedor cloud de EE. UU. que encadenó 21.755 sesiones con el comando `echo -e "\x6F\x6B"` (una comprobación de acceso, sin más acciones).

4. Origen de los ataques

País (del proveedor)	Conexiones	%	IP
Países Bajos	128.917	59,6 %	194
Estados Unidos	27.903	12,9 %	849
Francia	15.058	7,0 %	108
Alemania	10.149	4,7 %	132
Reino Unido	5.538	2,6 %	102
China	4.879	2,3 %	635

[FIGURA 2: `paises_origen.png`]

Los Países Bajos suman casi el 60 % de las conexiones con solo 194 IP: **12 de las 15 IP más activas pertenecen a un mismo proveedor** (Banatsync SRL, bloque 109.160.32.0/24 y alguna IP francesa). Es infraestructura de alquiler, no un país atacante. En cambio, Estados Unidos y China aportan muchas IP con pocas conexiones cada una, el patrón de botnets distribuidas.

Credenciales más probadas: usuario `root` (87.903 intentos), contraseñas `123456` (5.914), `123`, `1234` y `12345678`. Destaca la combinación fija **`345gs5662d34:345gs5662d34`** (4.440 intentos fallidos) y la contraseña `3245gs5662d34`, aceptada 4.002 veces con `root`: cadenas repetidas que apuntan a una misma herramienta, no atribuida a una familia concreta.

[FIGURA 3: `top_usuarios.png` y `top_passwords.png`]

5. Campañas identificadas

Se agruparon las sesiones por **huella HASSH** del cliente SSH (la misma huella indica la misma herramienta, aunque cambie la IP).

Huella (resumida)	Sesiones	IP	Comportamiento
0a07…	113.505	107	Todos los días del periodo. Fuerza bruta y reconocimiento (uname -s -v -n -r -m)
30d8…	26.994	39	10–27 oct. Verificación de credenciales y whoami
01ca…	21.754	1	20–21 oct. Bucle de comprobación de acceso (echo ok)
f555…	17.776	1.180	Botnet Outlaw. Inyección de clave SSH
1644…	6.806	91	Reconocimiento (/bin/./uname)
2ec3…	2.663	18	Script que comprueba si es un honeypot (filter), unos 8,5 comandos por sesión

(*) Valores calculados sobre el log completo. Otras 17.912 sesiones (2.260 IP) no completan el handshake SSH.

5.1 Outlaw / Dota (persistencia por clave SSH)

Secuencia: `cd ~; chattr -ia .ssh; lockr -ia .ssh`, luego borrado del directorio `.ssh` y escritura de una clave RSA propia con el comentario `mdrfckr` en `authorized_keys`. **4.597 sesiones desde 1.190 IP** (el hash del fichero descargado es el mismo en todas). Pasó de 441 IP en los primeros 13 días a 1.190 en 28: la botnet sigue creciendo. Técnicas: T1098.004, T1222.002.

5.2 RedTail (criptominado)

Subida por SFTP de binarios para varias arquitecturas (`redtail.arm7`, `.arm8`, `.i686`, `.riscv`, `.x86_64`) más `setup.sh` y `clean.sh`, **30 veces desde 3 IP**, solo el 5 de octubre. No ha vuelto a aparecer. Técnicas: T1105, T1496.001.

5.3 Dropper `.16` (desde el 24 de octubre)

Subida por SFTP de un fichero `.16` (600 veces, 15 IP) seguida de `chmod +x '/root/.16'` (538 veces). El hash cambia entre subidas (más de una docena de variantes), lo que sugiere un binario distinto por víctima. **No se ha analizado su contenido**; se describe solo por su comportamiento.

5.4 Verificación de credenciales

La huella `30d8…` (39 IP) valida credenciales y ejecuta `whoami` sin más acciones, a gran escala (26.994 sesiones, 10–27 de octubre). Es típica de la fase previa a la venta o reutilización de accesos.

5.5 Comprobación de honeypot

El script `filter` (`printf "#!/bin/bash\necho \"xxxxxx\"\n" > filter ...`) y la orden `echo xsec` (374 veces, 2 IP) comprueban si el entorno es un señuelo antes de continuar (T1497.001).

5.6 Reenvío de puertos

1.752 sesiones desde 58 IP piden a Cowrie reenviar tráfico TCP a terceros (T1090), por ejemplo a `62.210.131.144:2535` (855 veces) y `172.67.133.8:443` (527). Cowrie registra el intento pero **no reenvía** nada.

6. Técnicas MITRE ATT&CK

Se detectaron **24 técnicas en 9 tácticas** (tabla completa en el anexo, `mitre_mapping.csv`). Las más relevantes:

Táctica	Técnica	Sesiones	IP
Initial Access	T1078.003 Valid Accounts: Local Accounts	93.830	1.617
Credential Access	T1110.001 Brute Force: Password Guessing	103.003	1.583
Execution	T1059.004 Unix Shell	75.040	1.470
Discovery	T1082 System Information Discovery	31.770	325
Discovery	T1033 System Owner/User Discovery	16.895	174
Persistence	T1098.004 SSH Authorized Keys	4.628	1.194
Defense Evasion	T1222.002 File/Directory	6.806	1.217

Táctica	Técnica	Sesiones	IP
	Permissions Modification		
Defense Evasion	T1497.001 Virtualization/Sandbox Evasion	1.927	20
Command and Control	T1090 Proxy	1.752	58
Command and Control	T1105 Ingress Tool Transfer	696	58
Impact	T1496.001 Compute Hijacking	32	4

[FIGURA 4: `mitre_tecnicas.png`]

Hay **38.903 comandos sin técnica propia**: en su mayoría sondeos triviales como `echo -e "\x6F\x6B"` (21.754 veces), que no corresponden a una técnica de ATT&CK y se dejan sin clasificar a propósito.

7. Indicadores de compromiso (IOC)

Tipo	Valor	Contexto
SHA-256	a8460f446be540410004b1a8db4083773fa46f7fe76fa84219c93daa1669f8f2	Inyección de clave mdrfckr (Outlaw)
SHA-256	af77b643964afd794460d28ab8a11b0ec8790cd5463abfde126613a4f3bccd32	Script filter (comprobación de honeypot)
Cadena	mdrfckr	Comentario de la clave SSH inyectada
Fichero	.16	Dropper por SFTP (24 oct. en adelante)
Credencial	345gs5662d34 / 3245gs5662d34	Cadena fija de una misma herramienta
Servidor de malware	91.92.43.221	Descarga de iranbot-ultimate.* y cat.sh
HASSH	f555226df1963d1d3c09daf865abdc9a	Cliente libssh de Outlaw (1.180 IP)

La lista completa de hashes y URLs (56 ficheros, 13 URLs) está en `informe_resumen.txt`.

8. Recomendaciones defensivas

1. **Desactivar la autenticación por contraseña en SSH** y usar solo claves (`PasswordAuthentication no`). Neutraliza las 199.530 pruebas de credenciales (M1032, M1036).
2. **Prohibir el acceso remoto como `root`** (`PermitRootLogin no`) y no permitir cuentas con contraseñas triviales (M1026, M1027).
3. **Proteger `authorized_keys`** con permisos estrictos y control de integridad (FIM) para detectar la persistencia de Outlaw (M1022).
4. **Deshabilitar el reenvío TCP** (`AllowTcpForwarding no`) para evitar el uso como proxy (M1042).
5. **Filtrar el tráfico saliente** y montar `/tmp` con `noexec` para frenar descargas y ejecución de binarios (M1031, M1037, M1038).
6. **No basar la defensa en listas de IP**: el 79,5 % de las IP no repite día. Preferir huellas HASSH, detección por comportamiento y limitación de intentos.

9. Limitaciones

- Un solo sensor y 28 días: no permite medir tendencias a largo plazo.
- El “éxito” de login lo decide la política del señuelo.
- La geolocalización es la del proveedor de la IP.
- Las muestras de malware (como `.16`) no se han analizado dinámicamente.
- Las cifras con (*) proceden del log completo e incluyen los 213 eventos de pruebas propias (menos del 0,02 % del total).